

Hybrid Cryptography: A Framework for Post-Quantum Agility and Resilience

Kiril Ivanov

Department of Telecommunications
Technical University Sofia
Sofia, Bulgaria
mail: 4ikoivanov@gmail.com

Maria Nenova

Department of Telecommunications
Technical University Sofia
Sofia, Bulgaria
mail: mvn@tu-sofia.bg

Georgi Tsochev

Faculty of Computer Systems and
Technologies
Technical University Sofia
Sofia, Bulgaria
mail: gtsochev@tu-sofia.bg

Abstract—Quantum computing threatens classical cryptography, which has prompted the creation of post-quantum cryptography (PQC) and quantum key distribution (QKD). Hybrid cryptography integrates classical, post-quantum, and quantum techniques for achieving multi-layer security and smooth migration towards quantum-safe infrastructures. In this paper, practical deployment patterns, the employment of cryptographic agility, and integration of PQC with QKD are presented with emphasis on hybrid methods as a key strategy for quantum-secure communication.

Keywords—hybrid cryptography, quantum key distribution, post quantum cryptography, cryptographic agility, public key infrastructure, hybrid key derivation functions.

I. INTRODUCTION

The security of cryptography is founded on the hardness assumption of specific mathematical problems. Classical public primitives such as RSA, Diffie–Hellman key exchange, and elliptic-curve cryptography (ECC) obtain their security through the hardness of integer factorization and discrete logarithms over finite groups. While these problems remain classically computationally secure, Shor’s discovery of polynomial-time quantum algorithms on factoring and discrete logarithms addresses the fact that a large-scale quantum computer would compromise most existing public-key infrastructure (PKI) deployed today.

As preparation for this challenge, two mutually complementary research paths have materialized. Post-quantum cryptography (PQC) creates new primitives that defend against both classical and quantum attackers. Candidate sets consist of lattice-based schemes [1], code-based cryptography [2], hash-based signatures [3], and multivariate polynomial systems [4]. Those developments remain actively standardizing, most conspicuously through the NIST PQC process [5], which just made lattice-based schemes (e.g., CRYSTALS-Kyber, CRYSTALS-Dilithium).

At the same time, quantum cryptography, specifically quantum key distribution (QKD), exploits the principles of quantum mechanics to produce keys whose security comes from information theory. The early pioneer BB84 protocol [Bennett & Brassard, 1984] exploits the no-cloning theorem and measurement disturbance to indicate eavesdropping, while subsequent protocols such as E91 utilize entanglement-based correlations. Although QKD is costly requiring quantum channels and is limited in scalability, it provides a totally different physics-based paradigm of security rather than assumptions on computations.

Third emerging paradigm is hybrid cryptography, where classical, post-quantum, and quantum methods are orchestrated to maintain resiliency over diverse adversarial models (Fig 1.). Hybrid schemes already manifest in practice: TLS hybrid key exchange, blending elliptic-curve Diffie–

Hellman with lattice-based PQC [6], preserves secrecy unless the two schemes are concurrently compromised. Experimental systems combine QKD with classical key management to achieve better forward secrecy [7]. Hybridization facilitates smooth and flexible migration, enabling institutions to deploy PQC on their current infrastructures while future-proofing their institutions for quantum-native cryptographic primitives.

Hybrid Cryptography: Classical, Post-Quantum, and Quantum

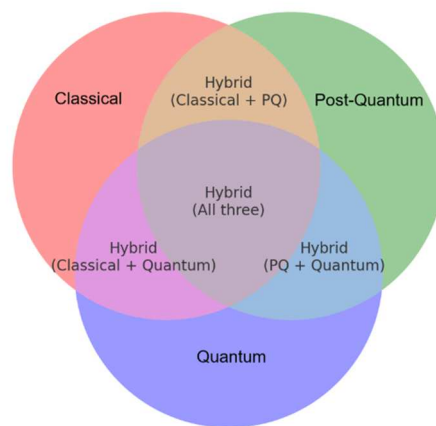


Fig. 1. Hybrid cryptography (Venn diagram showing the combinations between Classical, Post Quantum and Quantum cryptography).

Hybrid cryptosystems accordingly inherit an approach built on composability to protect: by stacking classical, post-quantum, and quantum assumptions on security on top of one another hoping to keep confidence and authenticity even when the attacker brings merely classical resources, scarce quantum devices, or fully scalable quantum computers to bear. This multi-pronged approach combines near-term practicality with long-term security and accordingly makes hybrid cryptography an important linchpin on the roadmap to secure communications.

II. HYBRID CRYPTOGRAPHY AND IMPLEMENTATION PATTERNS FOR POST-QUANTUM READINESS

When deploying post-quantum cryptography (PQC) in real systems, several implementation patterns stand out as both practical and forward-compatible.

Key Establishment (Hybrid by Default)
The safest baseline is to use hybrid key encapsulation mechanisms (KEMs), combining a classical algorithm with a PQC scheme. This ensures security against both classical and quantum adversaries.

- TLS 1.3: Advertise a hybrid key share such as X25519+ML-KEM-768 (Kyber-768) [8] first, with a

fallback to classical. The IETF's hybrid group drafts and ECDHE-MLKEM mapping make this approach interoperable with existing TLS negotiation. The impact on handshake size is modest—typically just one additional packet.

- HPKE: Register hybrid KEM [9] profiles (e.g., X25519+ML-KEM-768) and combine secrets using HKDF-Extract. RFC 9180's pluggable KEM design and CFRG hybrid combiner drafts make this straightforward for ECH, ODoH, or MLS extensions.
- SSH: Enable hybrid key exchange via `sntrup761x25519-sha512`, which pairs Streamlined NTRU Prime with X25519.
- IPsec/IKEv2: Production-ready options exist today. RFC 9370 [10] allows multiple key exchanges to include a PQC round alongside DH, while RFC 8784 supports PQ preshared keys for quantum-resistant confidentiality.

Sizing Considerations: ML-KEM-768 public keys are 1184 bytes and ciphertexts 1088 bytes, compared with 32–65 bytes for elliptic-curve points. Cloud measurements show this expands a TLS handshake by roughly one packet, which must be accounted for in buffer sizing, MTU, and early-data thresholds.

Post-quantum signatures introduce more significant size and performance trade-offs. Stateless PQC Signatures (Recommended for PKI): ML-DSA (Dilithium) is the standardized choice, with key and signature sizes varying by security level:

- ML-DSA-44: PK 1312 B, SIG 2420 B
- ML-DSA-65: PK 1952 B, SIG 3309 B
- ML-DSA-87: PK 2592 B, SIG 4627 B

Stateful Hash-Based Signatures: LMS/XMSS, standardized in SP 800-208, are well-suited for firmware or boot signing where signatures are few but long-lived. State management is critical—never reuse one-time keys, and store state securely (e.g., in an HSM).

Transitional PKI Options: Hybrid or composite certificates (LAMPS drafts) or dual certificate chains are emerging, while KEMTLS provides an alternative that avoids transmitting large PQ signatures in constrained environments. Lattice-based schemes must be implemented in constant time. Vulnerabilities such as KyberSlash [11] exploited secret-dependent operations in decapsulation. Use vetted libraries, verify constant-time execution, and follow NIST SP 800-227 draft guidance for input checks, failure handling, and KDF usage.

Key Derivation and Hybrid Combiners never combine secrets with ad-hoc XOR. Instead, mix classical and PQC shared secrets (and optional preshared keys) inside the KDF using HKDF-Extract with domain separation. CFRG's hybrid combiner drafts and NIST SP 800-56C provide the necessary framework while preserving transcript binding.

Hardware and Compliance for environments that require validated cryptography. NIST has standardized ML-KEM (FIPS 203) [12], ML-DSA (FIPS 204) [13], and SLH-DSA (FIPS 205) [14]. Testing under CMVP/ACVP already covers PQC algorithms, with vendors like AWS shipping validated modules.

Quantum key distribution (QKD) can be layered in as a preshared key input to KDF/KEM combiners, Fig. 2. Keeping protocol layering clean ensures interoperability. ETSI and ITU-T offer reference architectures and APIs for secure QKD integration into network environments.

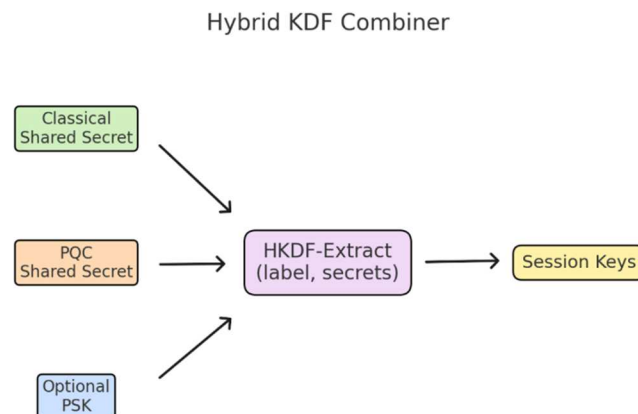


Fig. 2. Hybrid Key Derivation Function Combiner.

III. CRYPTOGRAPHIC AGILITY: DESIGNING FOR A POST-QUANTUM FUTURE

The concept of cryptographic agility lies at the heart of preparing digital infrastructure for the uncertainties of emerging cryptographic threats. Agility refers to the ability to replace or update cryptographic algorithms and parameters without disrupting users or requiring fundamental rewiring of the public key infrastructure (PKI). As advances in quantum computing threaten current cryptographic standards, agility ensures that systems can transition smoothly to post-quantum cryptography (PQC) or hybrid cryptographic frameworks.

The first step in achieving agility is establishing a thorough inventory and policy framework. Organizations must construct a “cryptographic bill of materials” that documents the algorithms currently in use, their parameters, and the systems that depend on them. This inventory then maps specific use-cases to suites of algorithms that can be deployed in the short term, in near-future scenarios, and in the eventual end-state where quantum-safe cryptography dominates. Guidance from agencies such as CISA, NIST, and the NSA emphasizes prioritizing exposures to “harvest-now, decrypt-later” threats, where adversaries collect encrypted traffic today in the hope of decrypting it once quantum resources become available. Migration tracks should be explicitly defined to mitigate these risks.

Beyond inventory, systems must retain negotiation headroom — the ability to incorporate new cryptographic mechanisms without ossification. For example, the GREASE mechanism in TLS introduces “unknown values” to ensure that extensions remain interpretable, preserving flexibility for future key encapsulation mechanisms (KEMs) and signatures. This capacity for negotiation provides a safeguard against protocol stagnation, allowing novel algorithms to be deployed without disrupting compatibility.

Equally critical are versioned encodings. Algorithm identifiers such as object identifiers (OIDs) and algorithm IDs must distinguish not only between classical cryptographic parameters but also between post-quantum and hybrid configurations. Certificate profiles must remain flexible, a goal actively pursued in IETF LAMPS drafts. Without this

flexibility, organizations risk having to reissue entire certificate hierarchies simply to accommodate new parameter sets — a costly and disruptive endeavor.

Practical deployment requires careful rollout strategies. New cryptographic configurations should be tested in controlled environments, often through regional or client-specific canaries, while logging negotiation outcomes to monitor performance and compatibility. Fail-open mechanisms can temporarily fall back to classical algorithms, but only where policy explicitly allows this. Particular attention must be paid to web protocols: post-quantum signatures and keys tend to increase handshake size Fig.3, triggering HelloRetry messages and certificate chain bloat. Measurement studies, such as those conducted by Cloudflare, offer valuable baselines for anticipating these impacts.

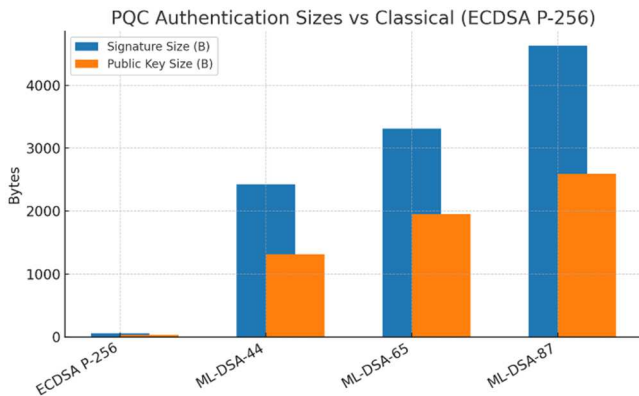


Fig. 3. Comparison between cryptographic algorithms and their sizes in bytes.

Another dimension is timelines and governance. Organizations subject to government standards must align with frameworks such as the U.S. Department of Defense’s CNSA 2.0, which sets deadlines for quantum resistance around 2035, with earlier milestones for critical functions such as software signing, browser-server communication, and VPNs. These milestones should be translated into product-level objectives and tracked through governance structures to ensure compliance and readiness.

From a practical standpoint, minimal “recipes” already exist to guide implementation. For TLS 1.3, a server can advertise support for hybrid key exchanges combining classical and post-quantum groups, accept post-quantum signature schemes such as ML-DSA, and ensure secret derivations are bound to the handshake transcript. Similar configurations exist for SSH, IKEv2, and HPKE, with specifications available from NIST and the IETF. These drop-in starting points allow organizations to experiment with hybrid deployments while monitoring handshake size, performance overhead, and certificate complexity.

Yet even with careful planning, organizations face common pitfalls. One challenge is fragmentation, where the increased size of post-quantum certificates causes packetization issues, especially under protocols like QUIC [15] that enforce strict maximum transmission units (MTUs). Solutions include trimming certificate chains, preferring shorter PQ signatures when security permits, and adopting emerging chain suppression techniques. Another critical issue is timing leakage, as non-constant-time code — such as division on secret data — can expose systems to side-channel attacks. Continuous analysis and micro-benchmarking are required to maintain constant-time guarantees, particularly after compiler updates. Finally, PKI inertia represents a

systemic challenge, as certificate authorities and ecosystems lag in adopting PQC object identifiers and hybrid path-building. Piloting dual-certificate approaches can bridge this gap until tooling matures.

To operationalize agility, organizations should turn on hybrid KEMs across TLS, SSH, and VPN deployments while logging negotiation statistics. They should test PKI with post-quantum signature levels, enforcing constant-time implementations in decapsulation routines, and relying exclusively on HKDF-based combiners [16] for hybrid key material. Alignment with CNSA 2.0 timelines and validation requirements such as FIPS 140-3 certification provides the governance backbone for this technical evolution.

IV. QUANTUM KEY DISTRIBUTION AND CLASSICAL CRYPTOGRAPHY

While post-quantum cryptography addresses algorithmic threats, quantum key distribution (QKD) offers a fundamentally different paradigm: information-theoretic security based on the laws of quantum mechanics. In hybrid models, QKD can serve either as an additional entropy source or as a replacement for part of the classical key exchange process.

In a baseline model, classical protocols such as TLS or IPsec rely on Diffie–Hellman exchanges to derive shared session keys. A QKD-augmented system introduces a parallel quantum channel that delivers fresh symmetric keys. These keys are then combined with the classical Diffie–Hellman output using a key derivation function, such as HKDF-Extract. This design ensures resilience: even if the classical key exchange is compromised by quantum algorithms, the secrecy of the session remains intact so long as the QKD system is uncompromised. Conversely, if QKD devices are vulnerable to side-channel attacks or device imperfections, the classical cryptography layer still maintains computational security.

Standards bodies such as ETSI and ITU-T have formalized architectures where QKD-derived keys are injected into classical stacks like IPsec or TLS via a dedicated Key Management System. Large-scale demonstrations have already validated these concepts, including China’s 2000 km QKD link and metropolitan projects within the European Union. Yet deployment challenges persist: long-distance QKD requires trusted nodes or satellite relays, and systems must address key synchronization, authentication, and scalability. Importantly, classical digital signatures remain necessary to prevent man-in-the-middle attacks, as QKD alone cannot provide authentication.

V. LAYERING QKD WITH POST-QUANTUM CRYPTOGRAPHY

A promising path forward lies in combining QKD with PQC, harnessing the complementary strengths of physical and algorithmic approaches. QKD delivers unconditional secrecy under physical assumptions, while PQC secures communication under mathematical hardness assumptions that are resilient to quantum attacks. Together, they create redundancy across paradigms.

In such a hybrid approach, a PQC key exchange (such as ML-KEM within TLS) runs alongside a QKD key stream. Both outputs are combined through a strong key derivation function (1):

$$K_{\text{session}} = \text{HKDF-Extract}(\text{salt}, K_{\text{PQC}} || K_{\text{QKD}}) \quad (1)$$

The resulting session key remains secure unless both sources are simultaneously compromised. This provides high assurance for critical infrastructures such as backbone networks or national defense systems. For these use cases, QKD mitigates “harvest-now, decrypt-later” attacks, while PQC enables immediate deployment at scale where QKD infrastructure may not yet reach.

Nevertheless, it must be emphasized that QKD cannot provide authentication on its own. Thus, post-quantum digital signatures such as ML-DSA or SLH-DSA remain essential to protect against impersonation and ensure trust in PKI. Standardization efforts are underway: ISO/IEC JTC 1/SC 27 is developing hybrid PQC-QKD guidelines, and ETSI is actively exploring integration within VPNs and 5G architectures.

VI. COMPARISON

Table I contrasts four cryptographic methods—classic, post-quantum, quantum, and hybrid cryptography—along multiple lines. Classic methods, for instance, RSA, ECC, and AES, are efficient and still dominant today but are at risk from quantum attacks on public key algorithms. Post-quantum cryptography (PQC), with schemes such as Kyber and Dilithium, depends on mathematical problems assumed not solvable on quantum computers, albeit often with longer keys and less efficacy; PQC is now going through NIST standardization and pilot deployment. Quantum cryptography, as represented by quantum key distribution (QKD), bases its security on the principles of physics instead of mathematics, yet needs specific hardware and has speed and range constraints and so best suits niche, extremely secure use cases. Hybrid cryptography uses different methods, for instance, ECC and Kyber or PQC and QKD, for the purpose of achieving protected migration with multilayered security, providing additional overhead and maximum resilience. Classic methods are predominant now, PQC will become mainstream, quantum best suits specialized use, and hybrid solutions represent a practical bridge on the way to quantum-resistant security.

TABLE I. DIFFERENT ASPECTS IN CRYPTOGRAPHIC SECURITY

Aspect	Types of cryptography			
	Classical	PQC	QKD	Hybrid
Examples	RSA, ECC, AES, SHA-2	ML-KEM, SPHINCS+, McEliece	QKD (BB84), Quantum RNG	ECC + ML-KEM, PQC + QKD
Security Basis	Hard math problems (factoring, discrete log)	Hard math problems believed safe vs. quantum (lattices, codes, hashes)	Laws of quantum physics (no-cloning, measurement disturbance)	Combination of two or more schemes
Quantum Resistance	Public-key broken by quantum (Shor) Symmetric only partly weakened (Grover)	Designed to resist quantum attacks	Security from physics, not math	If one scheme breaks, other still protects
Hardware Needs	Runs on classical computers	Runs on classical computers	Needs quantum channels	Runs on classical infra

Aspect	Types of cryptography			
	Classical	PQC	QKD	Hybrid
			(fiber/satellites, photon detectors)	(sometimes with quantum support)
Efficiency	Very efficient, small keys	Larger keys, slower in some cases	Very limited speed, distance constraints	Extra overhead, but transition-safe
Current Use	Dominates internet today (TLS, VPNs, digital signatures)	NIST standardization ongoing, pilots in TLS, VPN, messaging	Research, pilots in China, EU, satellite QKD	Early adoption in TLS 1.3 (Google, Cloudflare experiments)
Role in Future	Being phased out (for public-key)	Likely mainstream replacement	Niche (high-security communication)	Bridge during migration period

ACKNOWLEDGMENT

This work has been accomplished with financial support by the European Regional Development Fund within the Operational Programme “Bulgarian national recovery and resilience plan”, procedure for direct provision of grants” Establishing of a network of research higher education institutions in Bulgaria”, and under Project BG-RRP-2.0040005 “Improving the research capacity and quality to achieve international recognition and resilience of TU-Sofia (IDEAS)”.

REFERENCES

- [1] O. Regev, On lattices, learning with errors, random linear codes, and cryptography. STOC, 2005
- [2] R. McEliece, A public-key cryptosystem based on algebraic coding theory. DSN Progress Report, 1978.
- [3] D. J. Bernstein, D. Hopwood, A. Hülsing, T. Lange, R. Niederhagen, L. Papachristodoulou, M. Schneider, P. Schwabe, Z. Wilcox-O’Hearn. SPHINCS: practical stateless hash-based signatures, EuroCrypt 2015.
- [4] J. Patarin, Hidden fields equations (HFE) and isomorphisms of polynomials (IP): Two new families of asymmetric algorithms. EUROCRYPT 1996.
- [5] NIST. Post-Quantum Cryptography Standardization: Round 3 Finalists. National Institute of Standards and Technology., 2022
- [6] J. W. Bos, C. Costello, M. Naehrig, D. Stebila. *Post-quantum key exchange for the TLS protocol from the ring learning with errors problem*. 2015 IEEE Symposium on Security and Privacy, 2018.
- [7] S. Pirandola, *Advances in quantum cryptography*. Advances in Optics and Photonics, 2020.
- [8] R. Rios, J. A. Montenegro, A. Muñoz, D. Ferraris. Towards the Quantum-Safe Web: Benchmarking Post-Quantum TLS, 2024.
- [9] M. Campagna, A. Petcher, Security of Hybrid Key Encapsulation, 2020.
- [10] C. Tjhai, M. Tomlinson, G. Bartlett, S. Fluhrer, D. Van Geest, O. Garcia-Morchon, V. Smyslov. Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2), RFC 9370, 2023.
- [11] D. J. Bernstein, K. Bhargavan, S. Bhasin, A. Chattopadhyay, T. K. Chia, M. J. Kannwischer, F. Kiefer, T. B. Paiva, P. Ravi, G. Tamvada. KyberSlash: Exploiting secret-dependent division timings in Kyber implementations, 2024.
- [12] NIST, Module-Lattice-Based Key-Encapsulation Mechanism Standard, 2024.
- [13] NIST, Module-Lattice-Based Digital Signature Standard, 2024.
- [14] NIST, Stateless Hash-Based Digital Signature Standard, 2024.
- [15] J. Iyengar, M. Thomson, RFC 9000, QUIC: A UDP-Based Multiplexed and Secure Transport, 2022.
- [16] H. Krawczyk, Cryptographic Extraction and Key Derivation: The HKDF Scheme, 2010.